

The sorry state of skill distribution (Earlier structural validation contribution)

The sorry state of skill distribution (Earlier structural validation contribution) - Author not stated, GitHub.

- Published: 2026-02-17
- Original: <<https://github.com/cisco-ai-defense/skill-scanner/pull/25>>
- Preserved from: <https://github.com/cisco-ai-defense/skill-scanner/pull/25> (github-api) on 2026-09-09
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Add strict structure validator and JS/TS scanner support

- Repository: cisco-ai-defense/skill-scanner
- Opened by: tjade273
- Opened: 2026-02-17
- State: closed

Body

Summary

- Adds a strict pre-load structural validator (`SkillValidator` in `skill_scanner/core/strict_structure.py`) that checks skill directories against the Agent Skills spec before deeper analysis. Catches hidden files, symlinks, disallowed directories, disallowed file extensions, binary content, non-UTF-8 encoding, missing/malformed SKILL.md, and frontmatter field violations — collecting all errors rather than bailing on the first.
- Adds first-class JavaScript/TypeScript support to the scanner: new `javascript` / `typescript` file type classifications in the loader, full rule-engine coverage in the static analyzer (eval, child_process, Function constructor, fetch, fs access, secrets, obfuscation), and asset-level prompt-injection scanning for `.html` , `.css` , `.svg` , `.xml` , `.xsd` files.

- Evaluated against the top 100 skills on the skills.sh marketplace. Initial strict validator had a 31.5% false positive rate, primarily from overly narrow extension and directory allowlists. After triaging file types (allowing scannable text formats, rejecting binary), the FP rate dropped to 21.7% — remaining failures are genuine non-conformance (binary font/image assets, non-spec directories, symlinks).

Changes

New files

- `skill_scanner/core/strict_structure.py` — `SkillValidator` class, `ValidationErrorCode` enum (15 codes), `ValidationError` / `ValidationResult` dataclasses, `validate_skill()` / `validate_skill_or_raise()` convenience functions
- `tests/test_strict_structure.py` — 37 test cases across 6 test classes
- `evals/skills/marketplace/fetch_and_validate.py` — marketplace eval harness

Modified files

- `skill_scanner/core/loader.py` — added JS/TS extension-to-file-type mappings
- `skill_scanner/core/models.py` — `get_scripts()` now includes JS/TS
- `skill_scanner/core/analyzers/static.py` — `_scan_scripts()` processes JS/TS; `_scan_asset_files()` covers HTML/CSS/SVG/XML/XSD; referenced file scanning handles JS/TS
- `skill_scanner/data/rules/signatures.yaml` — 6 new JS-specific rules; JS/TS added to all cross-language rules (secrets, obfuscation, eval)
- `skill_scanner/core/__init__.py` — added `strict_structure` to `__all__`
- `skill_scanner/__init__.py` — exported `SkillValidator`, `validate_skill`

Archived from <https://github.com/cisco-ai-defense/skill-scanner/pull/25>. Rendered offline from the local Markdown copy.